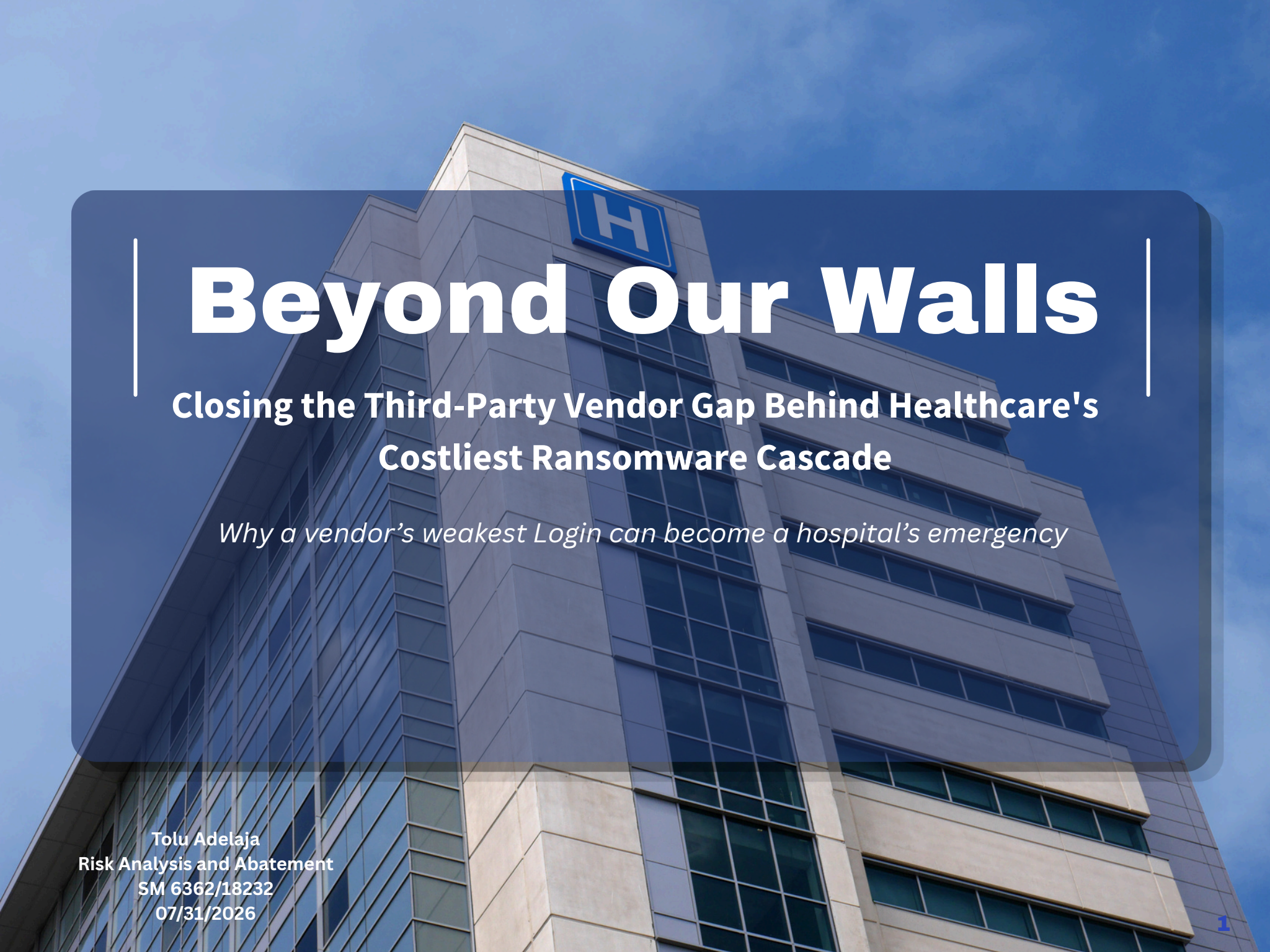




Beyond Our Walls

**Closing the Third-Party Vendor Gap Behind Healthcare's
Costliest Ransomware Cascade**

Why a vendor's weakest Login can become a hospital's emergency

Tolu Adelaja
Risk Analysis and Abatement
SM 6362/18232
07/31/2026

Executive Summary

Thesis: Applying the ASIS Enterprise Security Risk Management (ESRM) framework, Riverside Medical Center's asset inventory and risk-prioritization process (ESRM Steps 1–2) identified its claims, billing, and clinical data systems, reachable through the 1,300+ vendor relationships, as Riverside's highest-priority asset at risk. Modeled on the February 2024 Change Healthcare/UnitedHealth ransomware attack, closing that gap requires a formal, continuous Third-Party Risk Management (TPRM) program built on five pillars: vendor tiering, continuous monitoring, contract modernization, fourth-party risk mapping, and cross-functional governance.

Company & ESRM Asset Prioritization

Riverside's asset inventory (ESRM Step 1) and risk-based prioritization (ESRM Step 2) select vendor-connected claims, billing, and clinical data systems as the focus asset.

Background & Issue Identification

Claims, billing, and clinical data systems are the prioritized asset; CARVER analysis shows high vulnerability from unmanaged access across 1,300+ vendor relationships.

Organizational Risk

Unaddressed vendor risk threatens cash flow, patient care continuity, regulatory standing, and public trust.

Solutions Considered

Three options evaluated: enhanced vendor questionnaires, vendor tiering alone, and a continuous Third-Party Risk Management program.

Selected Solution & Path Forward

A five-pillar TPRM program tiering, continuous monitoring, Business Associate Agreement (BAA) modernization, fourth-party mapping, and governance across Riverside's vendor base.

Schedule & Metrics

18-month, three-phase rollout (Aug 2026–Jan 2028) tracked against vendor-tiering and monitoring coverage metrics.

Budget

\$430,450 total 18-month implementation; an estimated \$1.15M five-year program cost including ongoing monitoring and governance.

Company Overview

Riverside Medical Center

Private, nonprofit acute-care health system (an illustrative organization for this project)

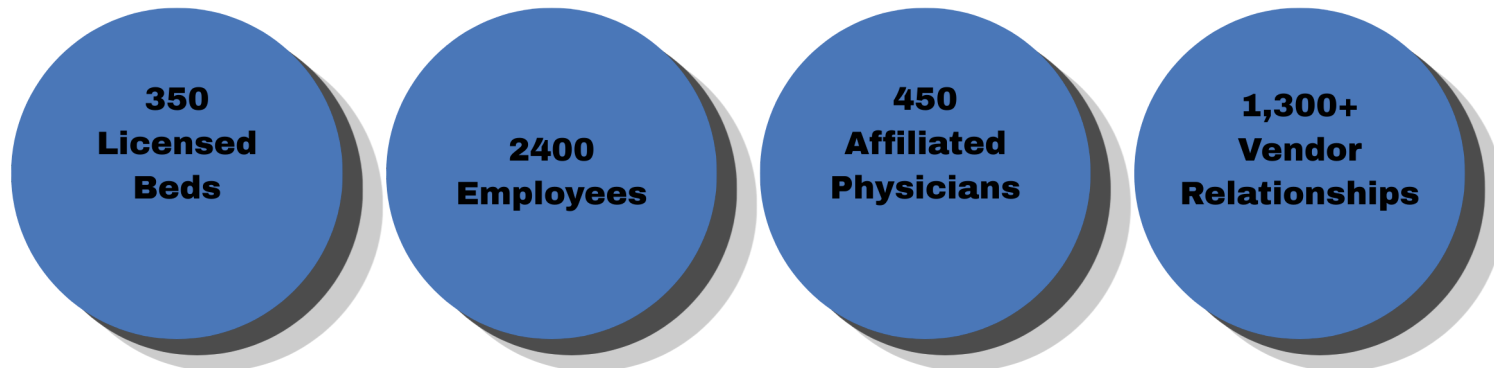
Mission: Deliver safe, high-quality acute and specialty care to the region while safeguarding patients, staff, and the community's trust.

Footprint: One main campus plus three outpatient clinics serving the Great Houston area.

Servicelines: Emergency Medicine, Surgical Services, Oncology, Behavioral Health, Diagnostic Imaging, and Inpatient Pharmacy.

Why ESRM, Why Now?

- Riverside depends on a network of more than 1,300 vendor relationships on average for claims processing, billing, and specialty IT services.
- One vendor's weak login can turn into a hospital-wide emergency, as the February 2024 Change Healthcare attack showed nationally (Pondurance, 2025).
- This applies the ASIS Enterprise Security Risk Management (ESRM) framework to systematically identify, prioritize, and mitigate the risk that third-party vendor access poses to Riverside's most exposed asset.



ESRM Step 1: Identify & Inventory Assets

Riverside depends on every asset to deliver care and remain licensed to operate

1. Claims, Billing & Clinical Data Systems

EHR, revenue-cycle, and claims/e-prescribing systems reachable through Riverside's 1,300+ vendor relationships.

2. Controlled-Substance Inventory

Opioids and benzodiazepines managed via 12 Automated Dispensing Cabinets.

3. Blood Bank & Biologics

On-site blood product storage supporting surgery and trauma care.

4. Radioactive Materials

Nuclear-medicine and oncology sealed sources and isotopes.

5. Physical Campus & Infrastructure

Power, medical gas, HVAC, and network backbone supporting the main campus.

6. Workforce & Key Personnel

Clinical staff and physicians whose availability and safety are mission-critical.

7. Brand Reputation & Patient Trust

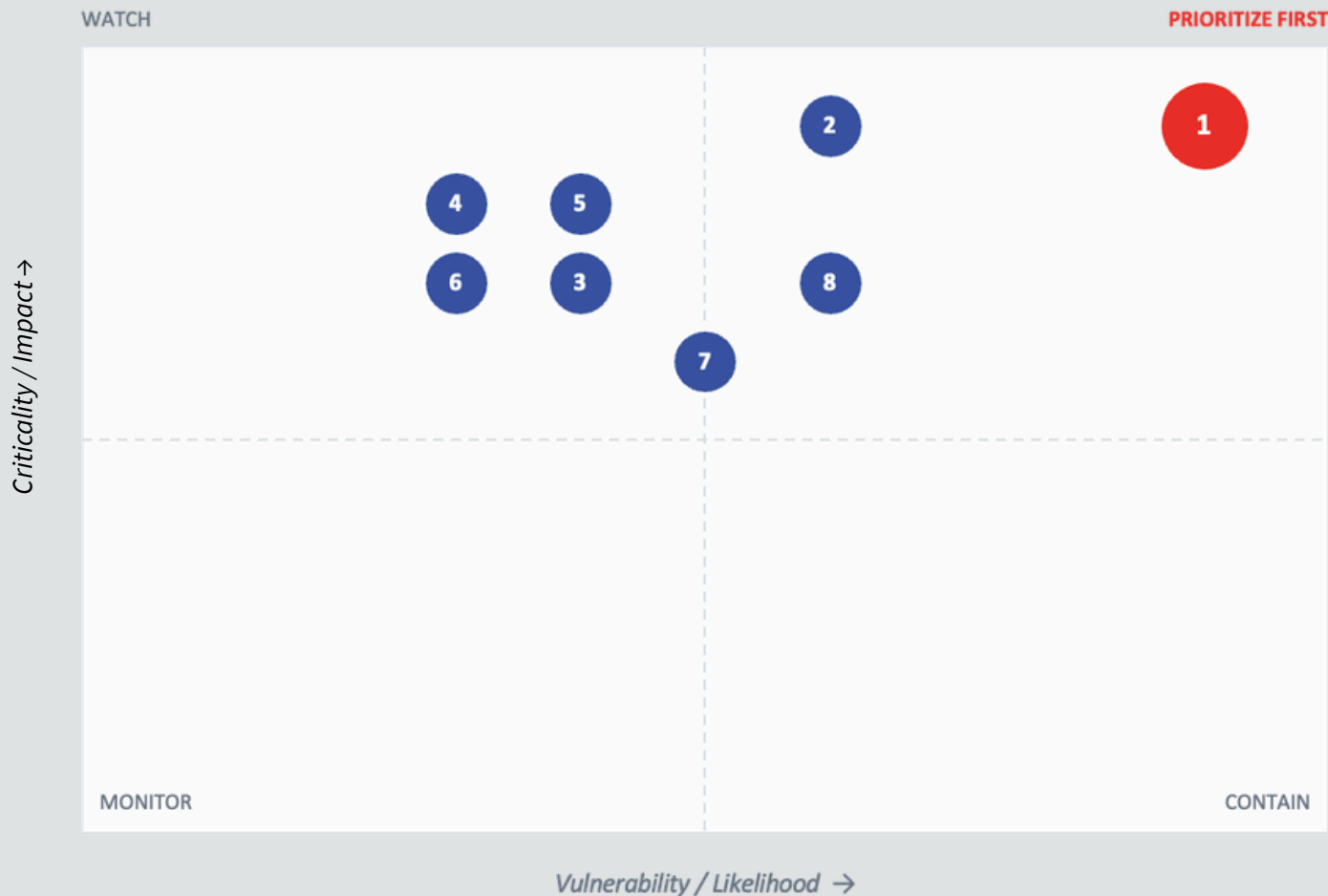
Community standing and patient confidence in Riverside's care.

8. Medical Device & IoT Fleet

Imaging, infusion pumps, and monitors remotely serviced and patched by device vendors.

ESRM Step 2: Prioritize Assets by Risk

Each asset scored on Criticality (impact if lost) and Vulnerability (likelihood of compromise)



Asset Register & Scores

1. Claims, Billing & Clinical Data Systems

C:9 V:9 — **SELECTED**

2. Controlled-Substance Inventory

C:9 V:6

3. Blood Bank & Biologics

C:7 V:4

4. Radioactive Material

C:8 V:3

5. Physical Campus & Infrastructure

C:8 V:4

6. Workforce & Key Personnel

C:7 V:3

7. Brand Reputation & Trust

C:6 V:5

8. Medical Device & IoT Fleet

C:7 V:6

Background & Issue Identification

A Closer Look at the Prioritized Asset

Asset: Claims, billing, and clinical data systems, Riverside's EHR, revenue cycle, and e-prescribing platforms.

Why it matters: A healthcare clearinghouse processes claims, prior authorizations, and prescription transactions for thousands of hospitals simultaneously. This means a single clearinghouse-level failure can produce major downstream effects across every connected health system.

Prioritization: In the ESRM Step 2 risk matrix, vendor-connected claims and clinical data systems scored highest on both criticality and vulnerability among Riverside's eight registered assets, reflecting how much operational reach the organization hands to its vendor ecosystem, placing this asset squarely in the “Prioritize First” quadrant.

Factor	Rating	Assessment
Criticality	High	Claims, billing, and e-prescribing all route through vendor-connected systems
Accessibility	High	1,300+ vendor relationships; many hold standing remote-access credentials
Recoverability	Low	Backlogged claims can be reprocessed, but cash-flow damage and exposed PHI cannot be undone
Vulnerability	High	Vendor remote access commonly lacks MFA; Riverside has no continuous visibility into vendor-side controls
Effect	High	One critical-vendor compromise can cascade to claims, billing, and prescriptions at once
Recognizability	Low	Attacker dwell time inside a vendor's own network can run 1–2 weeks before detection

Background & Issue Identification

The Incident: Modeled on the Change Healthcare Attack

Who: A national claims clearinghouse vendor used by Riverside for claims submission, prior authorization, and e-prescribing; a ransomware affiliate (modeled on ALPHV/BlackCat).

What: A single vendor remote-access account without multi-factor authentication (MFA) was compromised; ransomware later encrypted the vendor's platforms.

When: Detected in Q1 2026; the vendor's systems were down for roughly three weeks.

Where: The vendor's national data centers, impact felt at Riverside's billing office, pharmacy, and clinical units that rely on the platform.

How: Attackers used the unprotected remote-access account to move laterally for over a week before deploying ransomware, forcing the vendor to take its systems offline nationwide.

9 Days

attacker dwell time before
ransomware deployment
(industry precedent)

192.7 M

individuals affected
nationally by the reference
incident

94%

of hospitals nationally
reported financial impact
(AHA, 2024)

\$22M

ransom paid by the vendor
nationally (industry
precedent)

Context

This scenario is modeled on the real February 2024 Change Healthcare/UnitedHealth ransomware attack, the most consequential healthcare data breach in U.S. history to date. Nationally, 94% of hospitals reported financial impact and 74% reported direct patient-care impact from that single vendor incident; 33% reported disruption to more than half of their revenue (American Hospital Association, 2024).

Background & issue Identification

Root Cause & Regulatory Considerations

Root Cause Analysis

- Vendor's remote-access portal lacked mandatory multi-factor authentication; a control never verified during onboarding.
- No vendor tiering framework existed to flag this vendor as critical despite deep integration with claims, billing, and e-prescribing.
- Business Associate Agreement contained no minimum security-control requirements, monitoring obligations, or breach-notification SLA.
- No continuous monitoring in place across the 1,300+ vendor ecosystem, visibility relied entirely on annual, self-certified questionnaires.
- No manual/paper downtime procedure existed for claims submission or e-prescribing, so the outage became a direct cash-flow and patient-care event.

Regulatory & Standards Context

- HIPAA Security Rule (45 CFR §164.308) requires documented, risk-based due diligence on every Business Associate handling PHI.
- The U.S. Department of Health & Human Services Office for Civil Rights proposed HIPAA Security Rule update (Dec. 27, 2024) the first since 2013.
- HIPAA civil monetary penalties currently reach up to \$2.19 million per violation category; OCR cited Business Associate Agreement deficiencies as a contributing factor in numerous 2024 enforcement actions.
- NIST SP 800-161: Cybersecurity Supply Chain Risk Management Practices.
- HHS 405(d) Health Industry Cybersecurity Practices (HICP) guidance on third-party risk.

Organizational Risk

If no countermeasure is implemented, here is what Riverside Medical Center stands to lose.

Economic

The average healthcare data breach cost fell from \$9.77M in 2024 to \$7.42M in 2025, still highest of any industry for the 14th consecutive year (IBM, 2025).

Personnel & Safety

The American Hospital Association found 74% of hospitals reported direct patient-care impact, delayed authorizations & delayed medications, during the Change Healthcare outage.

Brand Media

A vendor's failure still lands on the hospital's doorstep in patients' eyes; national coverage of "hospitals can't fill prescriptions" followed regardless of whose network failed.

Environmental

Extended reliance on manual, paper-based downtime processes increases physical record handling and disposal exposure.

Regulatory Compliance

HIPAA penalties now reach \$2.19M per violation category, and OCR's pending Security Rule update would make documented vendor oversight a mandatory, annually-verified requirement.

Geopolitical

Ransomware affiliates often operate from jurisdictions outside U.S. law enforcement reach, and OFAC sanctions considerations complicate ransom-payment decisions.

Solutions Considered

Alternatives assessment: three options evaluated against the base case (status quo), at an 18-month horizon.

Option	Description	Estm. Cost	Effectiveness	Time to implement
Base Case (Status quo)	Point-in-time vendor assessments at contract execution, plus annual BAA renewals; no tiering, no continuous monitoring	\$0 (ongoing loss exposure)	None	—
A. Enhanced Vendor Questionnaire program	Accelerated semiannual (rather than annual) self-assessment questionnaires required of all 1,300+ vendors	\$68,000	Low	6-8 weeks
B. Vendor Tiering System (Alone)	Classify all vendors into Critical/High/Medium/Low tiers based on PHI access and integration depth, without continuous monitoring	\$151,000	Low-Medium	3-4 Months
C. Continuous TPRM Program (blended)	Vendor tiering, continuous automated monitoring, modernized BAAs, fourth-party risk mapping, and a Vendor Risk Governance Subcommittee	\$430,450	High (prevention+ detection+ governance)	18 Months (phased)

(A)Advantage: cheapest, fastest to launch. **Disadvantage:** measures vendor self-disclosure, not vendor security, Change Healthcare had a signed BAA and annual questionnaire on file when it was breached. **(B)Advantage:** correctly prioritizes limited oversight resources across 1,300+ vendors. **Disadvantage:** a classification exercise without monitoring goes stale within weeks. **(C)Advantage (recommended): it is the only option that both classifies vendor risk accurately and keeps that classification current through continuous monitoring, modernized contracts, governance, and combines tiering. Disadvantage:** highest cost and the only option requiring a multi-phase rollout.

Selected Solution & Path Forward

Option C: A Five-Pillar Third-Party Risk Management (TPRM) Program

Vendor Inventory & Tiering:

All active vendors catalogued and scored into Critical/High/Medium/Low tiers by PHI access, clinical-system integration depth, and concentration risk; clearinghouse and EHR vendors are Critical by default.

Continuous Monitoring:

An automated vendor-risk monitoring platform provides real-time visibility into security ratings and emerging vulnerabilities for all Critical- and High-tier vendors.

Contract Modernization:

BAAs are revised to require MFA certification, annual written proof of technical safeguards, 24-hour contingency-notification obligations, and audit rights for Critical-tier vendors.

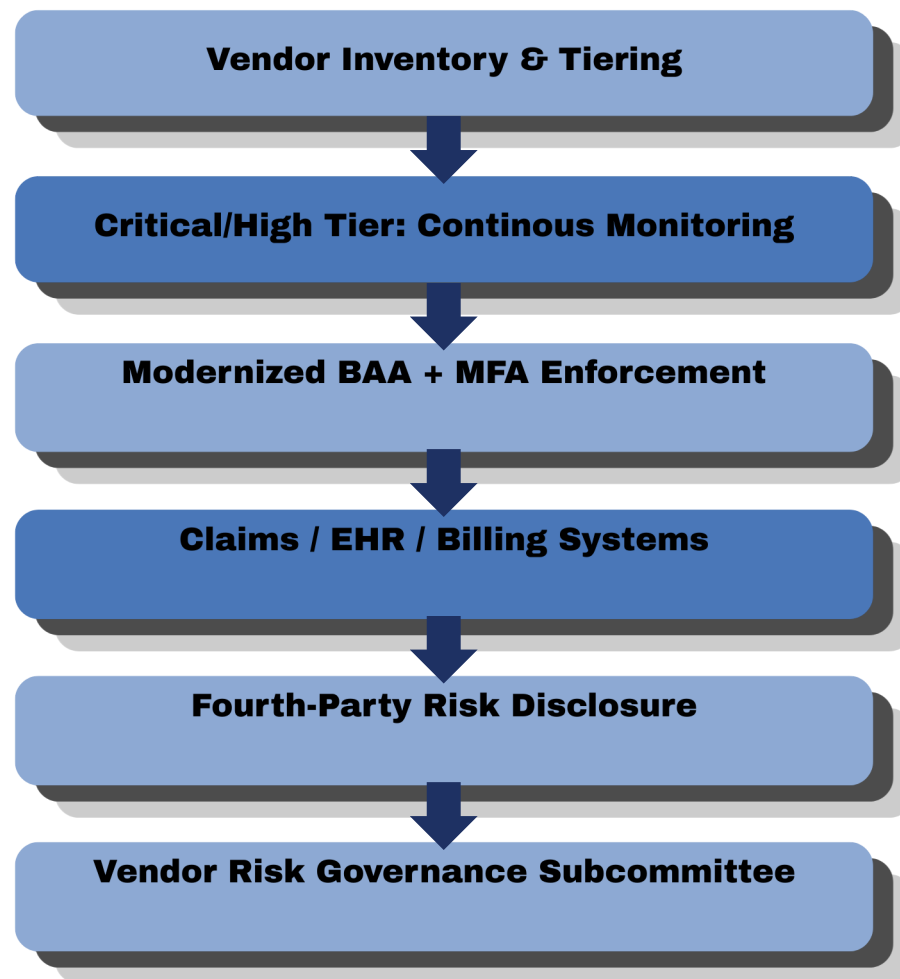
Fourth-Party Risk Mapping:

Critical-tier vendors must disclose material subcontractor relationships and confirm those subcontractors meet equivalent security standards.

Vendor Risk Governance Subcommittee:

A cross-functional Vendor Risk Governance Subcommittee (Security, Legal, Procurement, IT, Operations) reports quarterly and conducts a full annual program review.

Vendor Risk Platforms to Consider: UpGuard, Venminder, Riskconnect, and OneTrust, all of which centralize vendor inventories, automate security questionnaires, track BAAs, and monitor cyber and regulatory compliance risks. Venminder and Riskconnect serve as two of the top choices for healthcare environments.



Schedule

Three-phase rollout, August 2026 – January 2028 (18 months)

Phase 1 Foundation

Aug–Nov 2026 · Months 1–4

\$127,400

- Vendor inventory completion & tiering across all active relationships
- Business Associate Agreement revision & legal review
- Concentration-risk mapping for Critical-tier vendors

Deliverable: A completed, tiered vendor inventory and a revised BAA template ready for rollout.

Phase 2 Tech & Governance

Dec 2026–May 2027 · Months 5–10

\$213,750

- Continuous monitoring platform deployed for Critical/High-tier vendors
- Vendor Risk Governance Subcommittee chartered
- Fourth-party risk disclosure added to Critical-tier contracts

Deliverable: Live monitoring coverage for Critical/High-tier vendors and a functioning governance subcommittee.

Phase 3 Expansion & Optimization

Jun 2027–Jan 2028 · Months 11–18

\$89,300

- Monitoring coverage extended to Medium-tier vendors
- First annual program review & regulatory alignment assessment
- TPRM findings integrated into the enterprise risk register

Deliverable: Full-tier program coverage and a documented regulatory compliance posture.

Metrics

How we will know the program worked

100%

Critical & High-tier vendors under continuous monitoring by Month 10
(Phase 2 complete)

≤ 4 wks

Time to reclassify a vendor's risk tier after a security-posture change (vs. up to a year prior)

Quarterly

Vendor Risk Governance Subcommittee review cadence, plus a full annual program audit

Collection:

The continuous monitoring platform scores every Critical- and High-tier vendor's security posture and flags incidents in real time.

Review:

The Vendor Risk Governance Subcommittee (Security, Legal, Procurement, IT, Operations) reviews the dashboard and tier list monthly.

Reporting:

Quarterly summary to the enterprise risk governance committee; annual summary supports HIPAA Security Rule risk-analysis documentation.

Budget

18-month phased investment for the selected TPRM program

Phase	Cost Line Item	Subtotal
Phase 1: Foundation (Aug–Nov 2026)	Vendor inventory & tiering — \$38,200 BAA revision & legal review — \$41,600 Concentration-risk mapping — \$47,600	\$127,400
Phase 2: Technology & Governance (Dec 2026–May 2027)	Continuous monitoring platform — \$143,750 Governance Subcommittee setup — \$12,400 Fourth-party risk disclosure — \$57,600	\$213,750
Phase 3: Expansion & Optimization (Jun 2027–Jan 2028)	Monitoring extended to medium-tier vendors — \$51,800 Annual program review — \$22,700 Enterprise risk register integration — \$14,800	\$89,300
Total (18 Months)		\$430,450

18-Month Investment
\$430,450

EST. 5-YEAR PROGRAM COST
~\$1,150,000

\$430,450 is approximately 5.8% of the \$7.42M average cost of a single healthcare data breach (IBM, 2025), the program would pay for itself more than 17 times over if it prevents just one significant vendor-driven incident.

Conclusion

Recommendations

Approve \$430,450 in phased 18-month investment (Aug 2026–Jan 2028) to implement a five-pillar Third-Party Risk Management program, vendor tiering, continuous monitoring, BAA modernization, fourth-party risk mapping, and governance.

Approve renegotiation of all Critical- and High-tier Business Associate Agreements to require MFA certification, SOC 2/HITRUST reporting, and 24-hour breach/contingency notification.

Approve chartering of a cross-functional Vendor Risk Governance Subcommittee (Security, Legal, Procurement, IT, Operations) reporting quarterly.

Path Forward if Approved

Complete vendor inventory, tiering, and BAA legal review (Phase 1, through November 2026).

Deploy the continuous monitoring platform and charter the Governance Subcommittee (Phase 2, through May 2027).

Extend monitoring to medium-tier vendors and complete the first annual program review (Phase 3, through January 2028).

Integrate TPRM findings into the enterprise risk register on an ongoing basis.

Report vendor-tiering and monitoring-coverage metrics to the enterprise risk governance committee each quarter.

References

Allen, B. J., & Loyear, R. (2017). Enterprise Security Risk Management: Concepts and Applications. Rothstein Publishing.

American Hospital Association. (2024). Survey findings on hospital impact of the Change Healthcare cyberattack.

IBM. (2025). Cost of a data breach report 2025: Healthcare industry.

HIPAA Journal. (2025). 41% of 2024 third-party breaches affected healthcare organizations.

Pondurance. (2025). Practical strategies for vendor risk management in healthcare.

MSSP Alert. UnitedHealth Group: A cyberattack timeline.

National Institute of Standards and Technology. (2022). Cybersecurity supply chain risk management practices for systems and organizations (NIST SP 800-161, Rev. 1).

U.S. Department of Health and Human Services, 405(d) Program. Health industry cybersecurity practices (HICP).

U.S. Department of Health and Human Services, Office for Civil Rights. (2024, December 27). HHS proposes rule to strengthen cybersecurity for health information.

HIPAA Journal. (2026). What are the penalties for HIPAA violations? 2026 update.